CERBERUS SENTINEL

Penetration Test Report

PeriGen

December 2021

CONFIDENTIAL

Document Information

Document Control No	FINAL-01
Client Contact	Roman Lavrov <roman.lavrov@perigen.com>
Primary Contact	Rick Belisle <rick.belisle@cerberussentinel.com>
Technical Contact	Jason Scott <jason.scott@cerberussentinel.com>
Classification	Cerberus and Client Confidential This report contains Cerberus confidential information and may not be copied or distributed without written permission.

Table of Contents

1. **Executive Summary** 4
   - Scope Overview 4
   - Testing Timeframe 4
   - Risk Profile 5
   - Strategic Recommendations 5
   - Vulnerability Summary 6
2. **Compliance Findings** 7
   - PCI 7
   - Privacy Laws 7
   - HIPAA 8
3. **Adversary's Perspective** 9
   - Threat Potential 9
   - Attacker's View - External 9
   - Vulnerability Scans Identify Minor Issues 9
   - No Access to Systems or Customer Data 10
4. **Vulnerabilities - External** 11
   - L1. Strict Transport Security Not Enforced ..... **Error! Bookmark not defined.**
   - L2. Password Submitted Using GET Method ..... **Error! Bookmark not defined.**

Appendix: Supporting Data 12
- Observed Systems 12
- Extent of Testing 12
- Vulnerability Risk Ranking and Criteria 12

About Cerberus 14

1. Executive Summary

PeriGen engaged Cerberus Cyber Sentinel Corporation (Cerberus) to undertake a comprehensive security assessment known as a Penetration Test of select systems associated with the external environment.

Cerberus is a nationwide provider of cybersecurity consulting and managed services, with offices and resources across the US. Cerberus is a publicly traded company listed with ticker CISO. Cerberus Consulting Services deliver solution specialists with the wisdom and expertise to overcome your most challenging priorities.

The Cerberus Penetration Test is designed to identify security issues in the target environment, and more importantly, to put them in the context of the IT and business environment. All identified security controls and weaknesses are evaluated holistically to clearly demonstrate the potential impact on the environment so that the organization may target tactical and strategic initiatives where the need is most acute. By subjecting the environment to testing, PeriGen has demonstrated a strong commitment to understanding their true security posture and developing concrete risk mitigation strategies.

SCOPE OVERVIEW

The objective of the testing was to assess the information security posture of PeriGen's Fortinet firewall from an external perspective to determine risks posed from uncredentialed attackers.

The following targets were specified by PeriGen as in scope for this test:

Description	Address
External host	66.159.36.35
External host	66.159.36.36
External host	99.58.163.105
External host	99.58.163.106
External host	99.58.163.107

TESTING TIMEFRAME

The external testing was conducted in open windows (24x7) from Monday, December 20, 2021, to Thursday, December 23, 2021.

RISK PROFILE

Based on the results of this test, Cerberus considers the tested PeriGen Fortinet Firewall to be at a Low level of overall risk. Compared to other organizations assessed by Cerberus, the PeriGen environment tested in this engagement has a low exposure level from an external perspective.

No significant issues were found throughout the duration of this test.

Security controls were very well implemented. No notable issues were observed related to data handling, input validation, cross-site scripting, or file handling. No issues were identified that resulted in unauthorized access to any of the external hosts within the scope of this assessment.

Based on the results of the assessment and the security controls implemented on Perigen's external firewalls, it would take an advanced and highly skilled attacker to identify and exploit these external hosts.

Risk Summary

L Low Risk

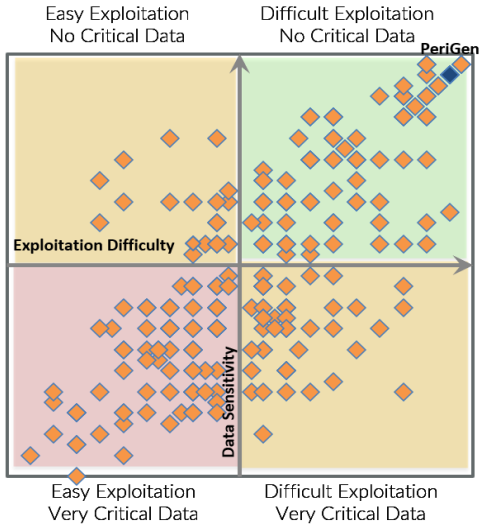
Threat Levels

L System Compromise

L Information Loss

L Service Disruption

Risk Chart



STRATEGIC RECOMMENDATIONS

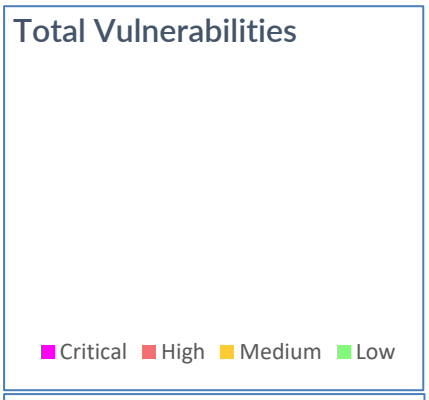
There appear to be proactive security capabilities that would hinder most types of attacks against Perigen's external firewalls.

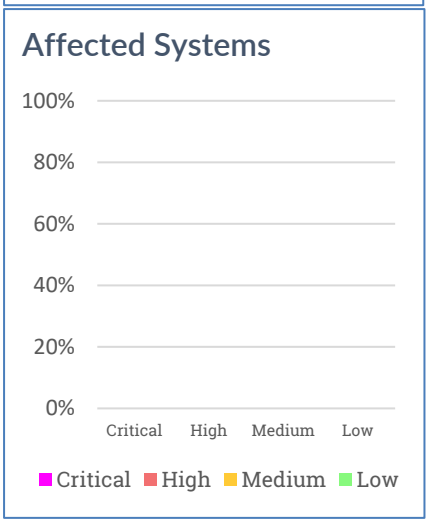
VULNERABILITY SUMMARY

No vulnerabilities were noted. As a result, no unauthorized access was made to external systems.

Automated scanning and manual validation were implemented during this test on all five remote hosts. The external hosts did not respond to Cerberus testing, implying the potential use of IP whitelisting.

In order to maintain integrity of the test and emulate external adversary threats as closely as possible, Cerberus IPs were not added to Perigen's whitelist.





2. Compliance Findings

Being affiliated with healthcare and patient information, PeriGen may be subjected to various standards associated with Personally Identifiable Information (PII), Protected Health Information (PHI), and HIPAA.

It is highly unlikely that the low-risk issues would lead to unauthorized or elevated system access that would result in the compromise of PII or PHI.

PCI

Compliance with the PCI standards has become an important issue within the merchant and service provider community over the last several years. The PCI Data Security Standard (DSS) is the set of security requirements originally created by the major credit card brands and now managed by the PCI Security Standards Council (SSC). PeriGen, and all business units, that store, process, or transmit credit card data are subject to these requirements and compliance is mandated per these requirements. This Penetration Test is part of PeriGen's overall PCI compliance effort as a yearly internal and external Penetration Test is required per PCI DSS requirement 11.3.

Cerberus did not identify any vulnerabilities during this assessment that had direct implications for PCI DSS compliance.

PRIVACY LAWS

Many states have privacy laws governing reporting of personal information that has been compromised. Taking CA as an example, SB1386/AB700 states:

"Notice of security breach: This bill requires a business or a State agency that maintains computerized data that includes specified personal information to disclose any breach of the security of that data to any California resident whose unencrypted personal information was, or is reasonably believed to have been, acquired by an unauthorized person. By giving consumers such notice, the bill gives them the opportunity to take proactive steps to ensure that they do not become victims of identity theft. [Chapter 915 of 2002]/[Chapter 1054 of 2002]"[1]

Cerberus did not identify any violations of U.S. privacy law throughout the duration of this assessment.

[1] http://www.oispp.ca.gov/consumer_privacy/privacy_leg/leg2002.asp

HIPAA

The Health Insurance Portability and Accountability Act[2] (HIPAA) defines a set of protections for safeguarding Protected Healthcare Information (PHI). HIPAA stipulates the controls that data should have in place, including Electronic and Technical safeguards. HIPAA also details monetary fines for disclosure of any PHI[3].

Cerberus did not identify any violations of HIPAA law throughout the duration of this assessment.

[2] http://www.cms.hhs.gov/HIPAAGenInfo/Downloads/HIPAALaw.pdf
[3] http://www.hhs.gov/ocr/hipaa/FinalEnforcementRule06.pdf

3. Adversary's Perspective

The purpose of this section is to demonstrate the susceptibility of the environment to attack and highlight those vulnerabilities that provided some level of access or control over systems, applications, and sensitive information. Information is presented in the order the events occurred, which provides insight into the evaluation criteria that attackers are using while they develop more valuable attack methods.

THREAT POTENTIAL

PeriGen provides labor and delivery teams with rich, real-time information at the bedside, remotely, and at nurse's stations to empower better patient care and safety. The healthcare industry is typically associated with high-value targets. In addition to potentially providing an avenue of attack to company business systems, attackers may attempt to target systems that could result in access to other partners as well.

ATTACKER'S VIEW - EXTERNAL

Baseline reconnaissance suggests PeriGen has a moderate Internet presence, most of which is maintained through providers such as WordPress and Go Daddy. Additionally, infrastructure services like DNS and mail are also hosted by Go Daddy and other third parties such as pphosted. Approximately 19 systems were referenced in Internet search services that included subdomains for securelink and WordPress-hosted web servers. While 79 employees are identified in LinkedIn, 184 email addresses for perigen.com users were found in basic searches.

The target scope for this test covers only a portion of the overall PeriGen infrastructure representing only external-facing firewalls. The two services identified consisted of one HTTPS web service using Fortinet Fortigate and one NTP service. See Observed Systems in the Appendix for additional detail.

VULNERABILITY SCANS IDENTIFY MINOR ISSUES

Automated vulnerability scans were initiated to collect data in parallel with manual testing. This did not identify any vulnerabilities that could be directly or easily exploited to gain unauthorized access to systems or data.

No notable issues were found during automated or manual testing.

NO ACCESS TO SYSTEMS OR CUSTOMER DATA

Ultimately, no vulnerabilities were identified during testing that could be used to obtain unauthorized access to the systems or data in the target scope.

4. Vulnerabilities - External

This section contains the vulnerabilities identified during testing of the external hosts along with supporting data, Cerberus' analysis of the vulnerability in relation to the target environment, and recommendations for addressing each issue.

Vulnerabilities are listed in order of severity from High (H), Medium (M), to Low (L), with risk rankings based on the NIST SP800-30 guidelines. Refer to the Appendix for further detail on the ranking methodology.

No vulnerabilities were identified throughout the testing of the external hosts.

Appendix: Supporting Data

OBSERVED SYSTEMS

From the target scope, a total of two services on one unique IP address were detected and evaluated during testing. A summary of these services is provided in the table below.

Table 1: Active services and application versions – External networks

Host	IP	Port	Port Name	Fingerprint
adsl-99-58-163-105.dsl.frs2ca.sbcglobal.net	99.58.163.105	123 8013	ntp N/A	Fortinet Fortigate
adsl-99-58-163-106.dsl.frs2ca.sbcglobal.net	99.58.163.106	N/A	N/A	N/A
adsl-99-58-163-107.dsl.frs2ca.sbcglobal.net	99.58.163.107	N/A	N/A	N/A
N/A	66.159.36.35	N/A	N/A	N/A
N/A	66.159.36.36	N/A	N/A	N/A

EXTENT OF TESTING

All systems within the target list were in scope for reconnaissance and baseline activities. All systems underwent automated and manual vulnerability scanning to identify as many potential weaknesses as possible. The testing timeframe allowed the evaluation of all network services visible to unauthenticated users.

All vulnerabilities found were evaluated and reviewed to verify their presence and help quantify the risk to the environment. If vulnerabilities were identified, they were only fully exploited to the degree necessary to evaluate the risk to the systems identified in the target scope with the explicit permission of client personnel.

VULNERABILITY RISK RANKING AND CRITERIA

Cerberus bases risk rankings on categories of risk based on the likelihood of the threat and the impact of the threat.

Risk Likelihood: The likelihood rating indicates the probability that a potential vulnerability may be exercised within the construct of the associated threat environment. This considers the threat-source motivation and capability, nature of the vulnerability, an existence and effectiveness of current controls.

Risk Impact: The impact a particular risk may have on an organization is based on the importance of how critical the asset is to the organization, the data that is stored on, or accessed via, that asset, and the sensitivity of the data stored on, or accessed via, that asset.

	Impact			
Threat Likelihood	Significant	Moderate	Minor	Negligible
Near Certain	Critical	Critical	High	Medium
Highly Likely	Critical	High	Medium	Low
Likely	High	Medium	Low	Informational
Rare	Medium	Low	Informational	Informational

About Cerberus

According to recent research "massive data fraud and theft" and "cyber-attacks" are now ranked in the top five enterprise risks by likelihood over the next ten-year period. Compounding this is the fact that machine learning and artificial intelligence are becoming more sophisticated and will ultimately be used to assist hackers in amplifying these risks. This trend is at the very core of why Cerberus was founded – the rules of the game are changing, and organizations cannot continue to rely on the same kinds of testing that has been done in the past.

Although most organizations understand the need to protect critical enterprise environments, the reality is that many remain at risk mostly due to the lack of specialized security expertise. The main advantage Cerberus offers our customers is our people - true industry leaders in the assessment arena.

We start by understanding our customer's business objectives because we know that security is not a one-size-fits-all process. The goal of each assessment is to view it as a unique environment. Although a standard methodology is followed for all our assessments, each engagement is thoroughly reviewed by a senior consultant that understands the cascading effects vulnerabilities can have. The results of every project are then manually reviewed and verified – relying on the experience of the tester and not an automated scanner. This is a critical differentiator in today's world of emerging threats. The result is a comprehensive approach to a risk management solution, which can be understood by both technical and executive staff.

Cerberus was founded by a team of elite security professionals, each bringing 20+ years of experience in the security industry, all with a specialty in security assessments. Our mission is to be a trusted name in the security industry, known for our technical knowledge, integrity, and business ethics. We do this by focusing on customer service and ensuring quality in everything we do.